

Relazione Tecnica: Vulnerability Assessment con Nmap e Nessus

1. Sintesi

Il presente rapporto analizza l'attività pratica di identificazione e valutazione delle vulnerabilità (*Vulnerability Assessment*) condotta su un'infrastruttura di rete simulata e isolata. L'obiettivo principale è stato la mappatura della superficie d'attacco dell'host target **Metasploitable** 192.168.50.101 per evidenziarne le falle critiche prima di una potenziale remediation. L'attività ha seguito una metodologia standard divisa in due fasi: una ricognizione mirata tramite **Nmap** per l'identificazione dei servizi attivi e una successiva scansione approfondita con **Tenable Nessus Essentials**. I test hanno rilevato un totale di **64 vulnerabilità**, di cui 9 classificate con livello di severità massima **Critical**, dimostrando la totale esposizione del sistema a minacce esterne.

2. Introduzione

Con l'evoluzione continua delle minacce cyber e la crescente sofisticazione delle tecniche di attacco, la mappatura proattiva delle falle di sicurezza è diventata un pilastro strategico fondamentale per garantire la business continuity. Non è più sufficiente proteggere il perimetro: occorre comprendere a fondo lo stato di aggiornamento e configurazione di ogni singolo asset di rete. Questa attività simula l'analisi di un server aziendale obsoleto contenente deliberatamente difetti di configurazione e servizi vulnerabili non patchati, permettendo di testare sul campo gli strumenti standard del settore.

3. Configurazione del Laboratorio e Troubleshooting di Rete

L'attività è stata interamente eseguita all'interno di un ambiente virtualizzato locale tramite Oracle VirtualBox per garantire il totale isolamento della sessione di test.

- **Target:** Metasploitable Linux 192.168.50.101 attestato su Rete Interna.
- **Attaccante:** Kali Linux 192.168.50.10 attestato sulla medesima Rete Interna.

4. Fase 1: Scansione di Rete e Fingerprinting con Nmap

In conformità con la traccia d'esame, la prima fase ha previsto una ricognizione manuale da terminale per mappare l'host attivo, identificare le porte aperte e fare il *banner grabbing* dei servizi in esecuzione.

Dal terminale di Kali Linux è stato eseguito il comando:

```
sudo nmap -sS -sV -O -p- 192.168.50.101
```

- **-sS**: Scansione di tipo TCP SYN Stealth, rapida e discreta.
- **-sV**: Rilevamento della versione esatta dei demoni software associati alle porte.
- **-O**: Fingerprinting del sistema operativo tramite analisi dello stack TCP/IP.
- **-p-**: Scansione estesa a tutte le 65535 porte TCP.

L'output ha evidenziato una quantità massiccia di servizi obsoleti esposti, tra cui spiccano server FTP (*vsftpd 2.3.4*), SSH, Telnet, server Web Apache, database MySQL e PostgreSQL, e istanze di condivisione file Samba.

```

kali@kali: ~$ ping -c 4 192.168.50.101
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=1.33 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=2.43 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=0.972 ms
64 bytes from 192.168.50.101: icmp_seq=4 ttl=64 time=0.972 ms

--- 192.168.50.101 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 307ms
rtt min/avg/max/mdev = 0.972/1.762/2.426/0.625 ms

kali@kali: ~$ nmap -sS -sV -p- -iL 192.168.50.101
Starting Nmap 7.90 ( https://nmap.org ) at 2020-07-09 09:48 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0028s latency).
Not shown: 65535 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet   Linux telnetd
25/tcp    open  smtp     Postfix smtpd
53/tcp    open  domain   ISC BIND 9.4.2
80/tcp    open  http     Apache/2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind  2 (RPC #10000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec     netbios-rc
513/tcp   open  login?
514/tcp   open  shell
1609/tcp  open  java-rmi OMI Classpath gmieregistry
1524/tcp  open  bindshell Metasploitable root shell
2849/tcp  open  nfs      2-4 (RPC #100003)
2121/tcp  open  ftp      ProFTPD 1.3.1
3306/tcp  open  mysql    MySQL 5.8.51a-Debian
3322/tcp  open  distccd  distccd v1 ((COM) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc      VNC (protocol 3.3)
6000/tcp  open  vll      (access denied)
6667/tcp  open  irc      UnrealIRCd
6897/tcp  open  irc      UnrealIRCd
8009/tcp  open  ajp33    Apache Jserv (Protocol v1.3)
8188/tcp  open  http     Apache Tomcat/Coyote JSP engine 1.1
8187/tcp  open  tcp      RubyGems RMI (Ruby 1.9; path /usr/lib/ruby/1.8/dm)
35520/tcp open  nlockmgr 1-4 (RPC #100021)
39520/tcp open  java-rmi OMI Classpath gmieregistry
43052/tcp open  moused   1-1 (RPC #100045)
53350/tcp open  status   1 (RPC #100024)
MAC Address: 08:00:27:8B:D3:8B (Oracle VM VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host) scanned in 164.06 seconds

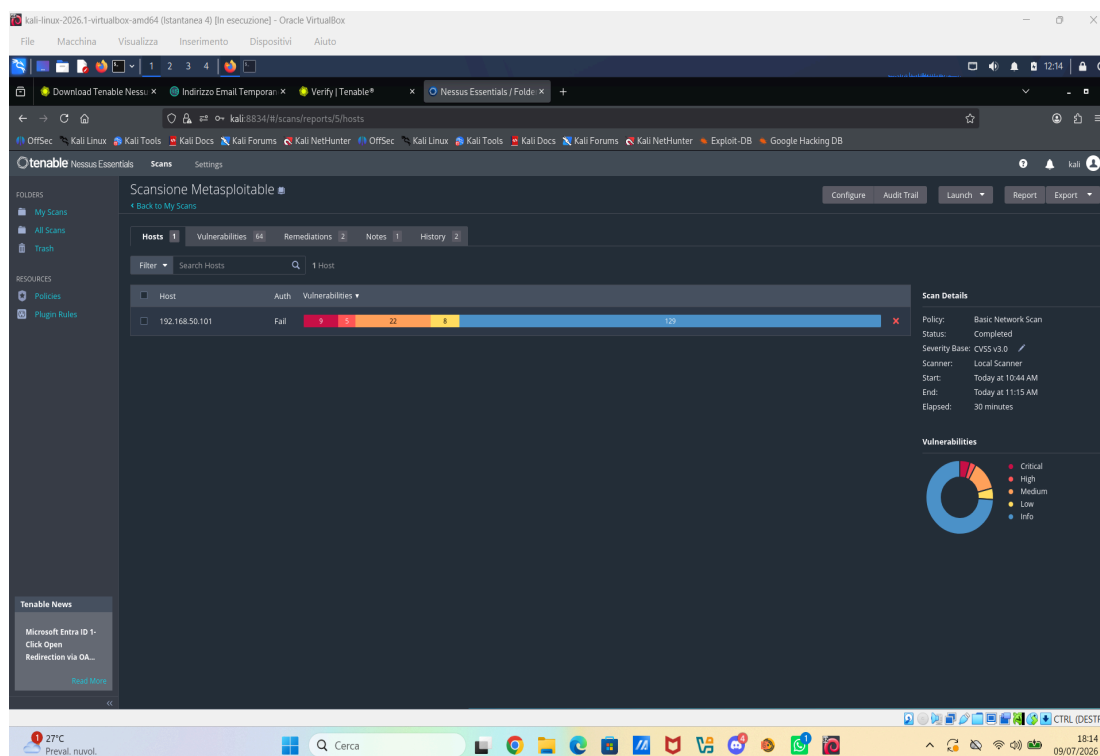
kali@kali: ~$

```

5. Fase 2: Scansione Automatizzata delle Vulnerabilità (Nessus)

Per soddisfare le richieste delle "Sfide Extra" della traccia, i dati raccolti da Nmap sono stati utilizzati per impostare una scansione approfondita su **Tenable Nessus Essentials** tramite una policy di *Basic Network Scan*. La scansione ha impiegato 30 minuti per correlare i servizi con il database dei difetti noti (CVE).

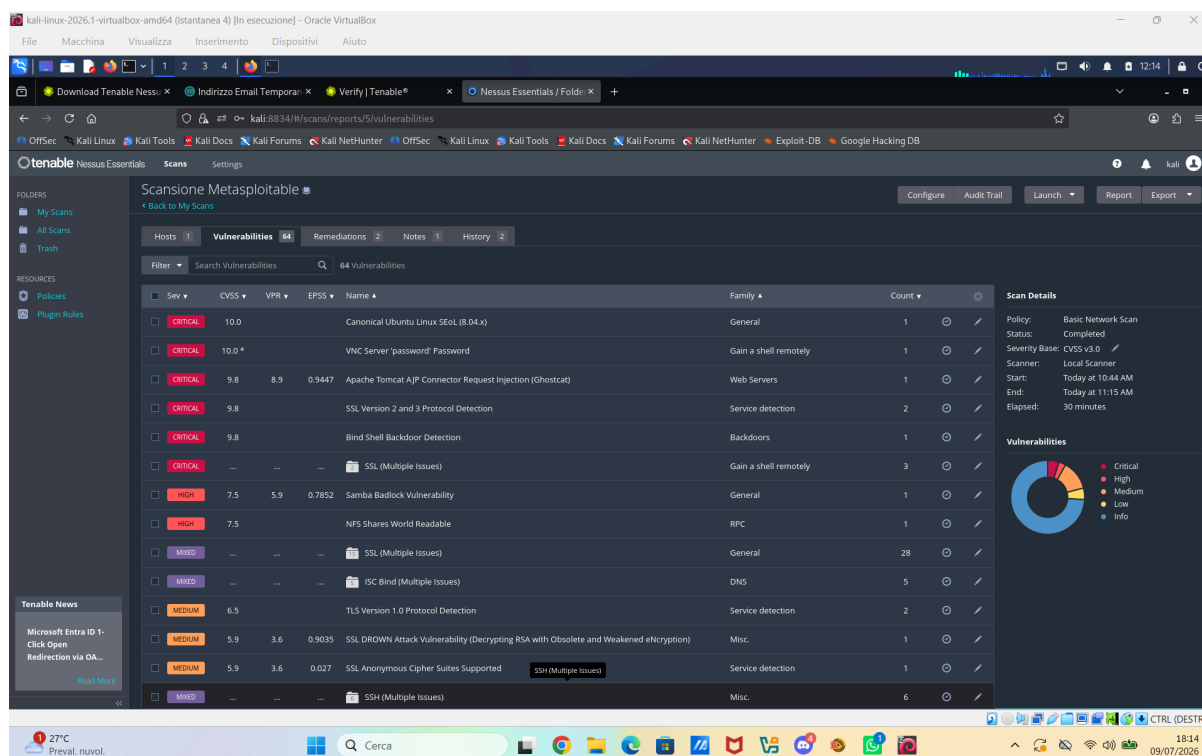
L'host ha confermato la presenza di **64 vulnerabilità totali**, distribuite tra falle critiche, alte e medie.



5.1 Analisi delle Vulnerabilità Principali Rilevate

Navigando nella scheda *Vulnerabilities*, lo strumento ha evidenziato in cima alla lista i vettori d'attacco più pericolosi:

- **VNC Server 'password' Password (CVSS 10.0 - Critical):** Il servizio di gestione remota grafica VNC è protetto da credenziali di default banali (**password**). Permette un accesso immediato al desktop del server.
- **Canonical Ubuntu Linux SEoL (8.04.x) (CVSS 10.0 - Critical):** Il sistema operativo è giunto al termine del ciclo di supporto (Support End of Life). Non riceverà mai più patch di sicurezza, esponendosi a exploit pubblici non mitigabili.
- **Bind Shell Backdoor Detection (CVSS 9.8 - Critical):** È stata rilevata una backdoor interattiva in ascolto su una porta aperta. Chiunque vi si colleghi riceve istantaneamente una shell di comando con i massimi privilegi di **root** senza alcuna richiesta di autenticazione.
- **Apache Tomcat AJP Connector Request Injection (Ghostcat) (CVSS 9.8 - Critical):** Vulnerabilità nel connettore AJP che permette l'inclusione di file e l'esecuzione di codice arbitrario da remoto.



6. Strategie di Difesa e Raccomandazioni (Remediation)

A seguito dell'analisi, si raccomanda l'applicazione immediata delle seguenti contromisure tecniche secondo un approccio di difesa in profondità:

1. **Dismissione e Migrazione:** Il sistema operativo Ubuntu 8.04 deve essere rimosso dalla rete e aggiornato a una distribuzione moderna con supporto a lungo termine (LTS).
2. **Hardening delle Credenziali:** Modificare e irrobustire tutte le credenziali di sistema e di applicazione, eliminando le credenziali predefinite presenti su VNC.
3. **Principio del Privilegio Minimo e Firewalling:** Chiudere tutte le porte non strettamente necessarie all'attività operativa (in particolare disattivare la Bind Shell identificata) e filtrare gli accessi tramite regole perimetrali stringenti.

7. Compliance e Framework Normativi

Il mantenimento in produzione di una macchina in questo stato viola pesantemente i requisiti minimi di sicurezza imposti dalle vigenti normative:

- **GDPR (General Data Protection Regulation):** La presenza di password banali e software non patchato configura una violazione diretta dell'Articolo 32 ("Sicurezza del trattamento"), esponendo l'organizzazione a pesanti sanzioni finanziarie per negligenza nella tutela dei dati.
- **Direttiva NIS2:** Per le infrastrutture e i settori considerati essenziali, la normativa impone l'adozione obbligatoria di processi di gestione delle vulnerabilità e aggiornamenti tempestivi, requisiti totalmente disattesi sul target in esame.

8. Conclusioni

L'attività di laboratorio ha dimostrato l'importanza strategica della cooperazione tra strumenti di ricognizione agili come Nmap e gestori strutturati come Tenable Nessus. Mentre il primo ha permesso di tracciare rapidamente le porte aperte, il secondo ha fornito il rigore tassonomico necessario a quantificare il rischio effettivo. I risultati evidenziano come una cattiva manutenzione e la mancata bonifica delle configurazioni di fabbrica espongono un sistema alla totale e immediata compromissione.